

Simple But Not Secure: An Empirical Security Analysis of Two-factor Authentication Systems

Xin Yang¹, Zhi Wang¹, Du Chen¹, Han Gao¹, Meiqi Tian², Yan Jia¹, and Wanpeng Li³

¹ College of Cryptology and Cyber Science, Nankai University, DISSec, Tianjin, China yx@mail.nankai.edu.cn, zwang@nankai.edu.cn, chendu@mail.nankai.edu.cn, hangao@mail.nankai.edu.cn, jiay@nankai.edu.cn

² Information Hub, Artificial Intelligence Thrust, The Hong Kong University of Science and Technology (Guangzhou), China mtian837@connect.hkust-gz.edu.cn

³ School of Computer Science and Informatics, University of Liverpool, Liverpool, UK wanpeng.li@liverpool.ac.uk

Abstract. Two-factor authentication (2FA) is widely used to reduce the risk of account takeover, but repeated challenges can impose a usability cost. Many websites therefore provide a “Remember the Device” option that suppresses future 2FA prompts for a period of time. We present **SE2FA**, a hybrid framework that combines web-scale dataset discovery, browser-assisted cookie analysis, and controlled cross-environment testing. We apply it to the Tranco Top 10,000 list and identify 940 websites that document or otherwise support 2FA; 495 were retained in the registrable subset after excluding sites that could not be registered. We find that 182 sites offer a remembered-device option and that 113 of them accepted remembered cookie state under our cross-environment test. Among these sites, 15 did not set **Secure** and 20 did not set **HttpOnly** on the identified trust-related cookies. These observations indicate potential exposure paths, but do not by themselves prove an exploitable network or XSS attack. We also confirm three previously undisclosed logic flaws that allow cross-account reuse or construction of accepted trust tokens in controlled experiments. We responsibly disclosed the findings and discuss design and deployment practices that reduce exposure while preserving usability.

Keywords: Two-Factor Authentication (2FA) · Risk Control · Web Authentication Security

1 Introduction

Web services increasingly store sensitive personal, financial, and organizational data, making account takeover a persistent security concern. Two-factor authentication (2FA) reduces the impact of password theft by requiring an additional verification factor [8]. At the same time, repeated 2FA challenges add friction to registration and login. To balance these goals, many services provide a “Remember the Device” option: after a successful 2FA verification, the service stores a trust decision and suppresses later challenges for a limited period [19,36].

The remembered-device decision is security-sensitive because it changes the conditions under which the second factor is requested. In practice, services implement this decision with browser cookies, browser fingerprints, IP or location signals, web storage, or combinations of these signals [2,8]. A cookie can be convenient and portable, but its security depends on how it is protected, bound to an account or device, rotated, and revoked. Conversely, a cookie configuration issue is not automatically an exploitable attack: a missing `Secure` flag exposes a possible network path only when an HTTP path is available, and a missing `HttpOnly` flag exposes a possible script-access path only when an XSS path exists. A browser with a malicious extension or malware is a stronger endpoint-compromise scenario that can affect many credential-storage mechanisms, not only cookies.

Existing studies have examined generic web authentication cookies, U2F-specific remember-me implementations, browser-fingerprint authentication, and the availability of MFA and risk-based authentication [2,8,25]. However, a large-scale study focused on web-based 2FA remembered-device implementations, their observable cookie properties, and their black-box logic behavior remains limited. We address this gap with SE2FA, a hybrid workflow consisting of (i) 2FA Spider and 2FA Reviewer for candidate discovery, (ii) the 2FA Extension and expert validation for cookie identification, and (iii) controlled tests that import trust state into a distinct environment and exercise cross-account or token-construction cases.

We apply SE2FA to the Tranco Top 10,000 list. The union dataset contains 940 sites. Of these, 495 were registrable for account-based testing; 182 of the 495 offered a remembered-device option; and 113 of the 182 accepted imported trust state in our cross-environment test. We identify configuration weaknesses and three previously undisclosed design flaws. Our goal is to measure observable security exposure and reproducible bypass behavior, while making the assumptions and limitations of each measurement explicit. In summary, we make the following contributions:

- We design **SE2FA**, a hybrid framework for discovering and evaluating real-world 2FA remembered-device implementations.
- We build a dataset of 940 2FA-supporting websites from 2FA Spider and the 2FA Directory, including 432 Spider-only candidates and 103 new sites contributed after validation.
- We characterize 182 remembered-device implementations and 113 sites that accepted imported trust state under a different IP address and browser fingerprint; we report cookie configuration observations together with their attack prerequisites rather than treating every observation as a confirmed exploit.
- We confirm three previously undisclosed logic flaws involving cross-account reuse or accepted predictable/constructible trust values, and responsibly disclose them to the affected providers.

Ethics Concerns. Given the severity of our findings, we responsibly disclosed the results to the affected vendors through their designated security con-

tacts, sharing our methods and a demonstration video. All experiments used test accounts and personal devices, without impacting other users. To prevent misuse, we have anonymized the names of the affected websites in this paper.

2 Problem and Approach Overview

In this section, we review two-factor authentication (2FA) systems, highlight security issues related to the “Remember the Device” feature, and outline the challenges of empirically analyzing 2FA implementations along with our approach to address them.

2.1 Two Factor Authentication

Knowledge-based authentication systems, which rely solely on usernames and passwords, are vulnerable to phishing, brute-force attacks, and large-scale data breaches [7,16,21]. To mitigate these risks, service providers are transitioning from single-factor authentication (SFA) [4] to multi-factor authentication (MFA). Among MFA options, two-factor authentication (2FA) is the most widely adopted form, which requires an additional verification factor beyond the password. One-time passwords (OTPs) are the most common, adding a layer of protection even if a password is compromised [10]. OTPs are generated periodically or per authentication attempt based on a seed and user-specific factors [15,32]. In practice, service providers validate the OTP submitted by the user through diverse delivery or generation methods, such as authenticator applications [3], Short Message Service (SMS), phone calls, hardware tokens, or email.

2.2 Risk-Based authentication for 2FA

To prevent unauthorized access, service providers often employ various risk control measures designed to detect potentially fraudulent login attempts [36]. However, to balance security with usability, many websites offer a “Remember the Device” option, allowing users to designate specific devices as “trusted” [25]. This enables users to bypass 2FA prompts when logging in from the same device within a valid period. In the following, we outline the main risk control measures commonly used to implement this feature.

Cookie-Based Risk Control. A widely used approach for risk control in 2FA systems is the use of browser cookies [25], a technology natively supported by web browsers. In 2FA systems, particularly those that implement the “Remember the Device” feature, cookies are employed to identify “trusted” devices [17]. For example, some websites use a cookie named `2fa_devices` to mark a device as “trusted”. When this cookie is included in the login request, the server recognizes the device as trusted, allowing the user to bypass the 2FA prompts during subsequent logins.

Fingerprint-Based Risk Control. Browser fingerprinting is a technique used to uniquely identify users by collecting characteristics related to their browser

and device [1,35]. Due to its high accuracy and representativeness, browser fingerprinting is integrated into the risk control in 2FA systems to enhance usability [20]. During the login process, the website generates a fingerprint of the user’s browser and sends it to the server. The server compares this fingerprint with those of previously “trusted” devices. If a match is found, the device is deemed “trusted”, enabling the user to bypass the 2FA prompt during login.

Other Risk Control Measures. During our security analysis of 2FA system implementations, we identified one website that employs `localStorage` [22] to retain information for identifying “trusted” devices within the user’s browser (see Section 5.2). Additionally, some websites incorporate the user’s IP address as part of the risk control mechanisms for their 2FA systems, requiring 2FA challenges even when users log in from the same device but with a different IP address [37]. Some websites combine multiple risk control measures to enhance the “Remember the Device” feature and improve the usability of their 2FA systems. For example, `planfix.com` uses both browser cookies and browser fingerprints to verify trusted devices. In this case, users must log in using the same browser with the “Remember the Device” option selected previously to avoid 2FA prompts during subsequent logins.

2.3 Observation and Attacks

Observation. Although the “Remember the Device” feature in 2FA is designed to improve usability, improper implementation can inadvertently compromise the security of the 2FA system. Lin et al. [20] showed that attackers could steal user browser fingerprints through phishing attacks, thereby deceiving service providers into believing login attempts come from a “trusted” device. This allows attackers to bypass 2FA and gain unauthorized access to the victim’s account. However, there is currently a lack of comprehensive security analysis of the 2FA “Remember the Device” implementations that rely on cookies, as well as the potential risks and vulnerabilities associated with this approach. To address this gap, we reviewed the top 10,000 websites in the Tranco’s list ⁴ and identified 940 online services that support 2FA. Our study found that 182 sites implemented the “Remember the Device” feature, with more than half relying entirely on 2FA cookies to store information about “trusted” devices. We also highlight the security risks and potential attack vectors associated with using browser cookies as the sole factor in risk-based authentication.

Attacks. We define an adversary model for evaluating 2FA systems that use cookies to implement the “Remember the Device” feature. Throughout this paper, we refer to a cookie as a **2FA Cookie** when controlled testing shows that it contributes to the server’s decision to recognize a previously remembered device and suppress a fresh 2FA challenge. This is a functional definition: a 2FA Cookie does not necessarily contain an OTP or another authentication factor, and an ordinary session cookie is included only when our tests show that it affects the remembered-device decision.

⁴ <https://tranco-list.eu/>, assessed 09-17-2025

We assume that the attacker has obtained the victim’s first authentication factor (e.g., username and password) through phishing or a prior credential breach [7,16], but does not possess the victim’s second factor. Attacks against second-factor enrollment are outside our scope. Attacks A1–A3 examine different ways in which an attacker may obtain and replay the victim’s 2FA Cookie, whereas A4 considers logic flaws that allow the attacker to bypass 2FA without obtaining the victim’s legitimate 2FA Cookie.

(A1) Man-in-the-Middle (MITM) Attack: A **network attacker** may intercept a 2FA Cookie if the cookie does not carry the **Secure** attribute and the browser transmits it over a non-TLS connection [28,31]. Therefore, a missing **Secure** attribute represents a potential transport-exposure condition, but does not by itself demonstrate that an exploitable HTTP path exists.

(A2) Cross-Site Scripting (XSS) Attack: A **web attacker** who can execute a script in the target origin may read a 2FA Cookie when the cookie does not carry the **HttpOnly** attribute [27]. Accordingly, a missing **HttpOnly** attribute represents a potential script-access condition; exploitation additionally requires an independently available XSS path.

(A3) Man-in-the-Browser (MITB) Attack: A **MITB attacker** with browser-level control through malware or a malicious browser extension may access and exfiltrate 2FA Cookies despite the **Secure** and **HttpOnly** attributes [23,24,34]. This is a strong endpoint-compromise threat that can also affect session cookies and other browser-stored credentials, rather than a vulnerability specific to 2FA Cookies. Our evaluation therefore uses A3 to determine whether an acquired 2FA Cookie can be replayed in a different browser environment.

(A4) Logic Flaw Attack: Design or implementation flaws, such as missing account binding or insufficient integrity validation, may allow an attacker to reuse a 2FA Cookie issued to an attacker-controlled account or construct a value that the server accepts for the victim’s account. This attack does not require access to the victim’s legitimate 2FA Cookie or second factor. We confirm a logic flaw only when an attacker-supplied value successfully suppresses the victim’s 2FA challenge in a controlled experiment. A readable structure, predictable-looking field, or reversible encoding alone is not considered sufficient evidence of exploitability.

3 Design

In this section, we describe the data collection process for websites that support 2FA with the “Remember the Device” feature, as well as the methodology used to analyze 2FA security mechanisms. Figure 1 presents the framework of SE2FA.

3.1 Dataset Collection

While the 2FA Directory offers similar data, it relies on community input and misses many 2FA-enabled sites. To build a more complete dataset, we developed **2FA Spider**⁵, an automated crawler that identifies websites potentially

⁵ <https://github.com/Yang-Nankai/SE2FA>

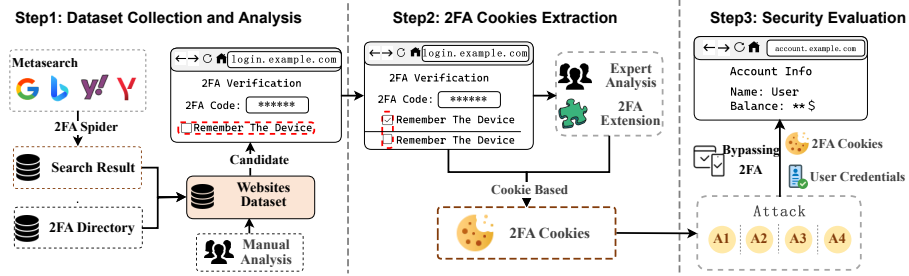


Fig. 1: **SE2FA Architecture**. SE2FA combines meta-search, regex filtering, and LLM analysis to identify websites supporting 2FA and the “Remember the Device” feature. It then extracts 2FA cookies using the *2FA Extension* and manual review, and evaluates their security in a controlled attack simulation.

supporting 2FA. Inspired by Jannett et al. [18], who used meta-search to locate single sign-on pages, 2FA Spider employs the SearXNG [29] meta-search engine to aggregate results from Google, Bing, Yandex, and Yahoo. For each domain, it retrieves the top five valid results (URLs, titles, and snippets), based on the observation that official 2FA setup pages almost always appear within the first page of search results.

To reduce false positives, a two-stage filter is applied. In the first stage, we removed duplicate secondary domains, retaining the main site based on domain importance (e.g., keeping “google.com” and excluding “google.hk” and “google.fr”). We then excluded domains related to educational and government institutions (e.g., “.edu” and “.gov”), as these often require additional registration and login information. Finally, we matched titles and snippets against a predefined set of keywords (e.g., “2FA”, “two-factor authentication”, “one-time code”). Entries below the relevance threshold were discarded. In the second stage, to further enhance precision, we developed an automated review tool, **2FA Reviewer** (Figure 1), powered by a large language model (LLM). Built on the GPT-4o model, it incorporates carefully designed prompts and browser-interaction capabilities to automatically verify whether each candidate URL leads to the official 2FA documentation of the corresponding website. The tool also identifies sites that rely on third-party authentication (e.g., “outlook.com” using Microsoft accounts), which we exclude from our dataset since their 2FA mechanisms rely on the third-party accounts and are analyzed separately. Keyword filtering reduces the candidate set before manual inspection. The LLM stage helps prioritize and review candidate documentation, but its independent classification accuracy was not established with a separately adjudicated gold-standard set in this study. We therefore report the comparison with the 2FA Directory as dataset overlap/coverage, not as an LLM accuracy measurement.

Using the 2FA Spider, we initially identified 897 websites supporting 2FA. Our results overlap with 465 of the 508 sites in the 2FA Directory (91.7% of Directory entries). This number is a coverage/overlap statistic rather than accuracy, because the Directory is community-maintained and is not a complete

2FA Spider(D_1)	2FA Directory(D_2)	$D_1 - D_2$	$D_2 - D_1$ (FN)	$D_1 \cap D_2$ (TP)	$D_1 \cup D_2$ (Total)
897	508	432	43	465	940

Table 1: **Comparison of 2FA Directory and Our 2FA Spider.** $D_1 - D_2$: only in 2FA Spider; $D_2 - D_1$: only in 2FA Directory; $D_1 \cap D_2$: matched websites; $D_1 \cup D_2$: total websites.

ground truth. The 432 Spider-only sites and the 43 Directory-only sites motivate the union dataset of 940 sites. After excluding restricted domains, 103 validated sites were contributed to the Directory.

We combined data from 2FA Spider and the 2FA Directory to create a dataset of 940 2FA-supported websites (Table 1). We manually analyzed these websites to evaluate whether they offered a registration option, supported 2FA, and implemented the “Remember the Device” feature. We categorized them into groups:

G1: Websites that cannot be registered (e.g., sites requiring product purchase or contact for registration).

G2: Websites supporting registration and 2FA but restricting 2FA activation to premium or enterprise accounts.

G3: Sites supporting 2FA without a “Remember the Device” feature.

G4: Websites that support registration, 2FA, and the “Remember the Device” feature.

The categorized data is shown in Table 2. We identified 182 websites that fall into the G4 category. For each website, we created two accounts to conduct testing and verification, ensuring that 2FA was enabled on both accounts.

Group	Description	Number	
G1	Cannot be registered	445	
G2	2FA cannot be enabled	61	
G3	2FA without “Remember the Device”	252	
G4	2FA with “Remember the Device” (Cookie-Only Measure)	113	182
	2FA with “Remember the Device” (Other Measures)	69	

Table 2: 2FA-Supported Websites and Risk Controls

3.2 2FA Cookie Extraction

In this step, we combine automated tools with manual review to extract and analyze 2FA cookies from target websites (see step 2 in Figure 1). Because websites use cookies for diverse purposes and no dedicated tools currently exist for 2FA cookie analysis, fully automating this process remains challenging. The variety of 2FA implementations and presentation methods further complicates detection and interpretation.

To address these challenges, we adopt a hybrid approach that integrates automated cookie extraction with expert validation, ensuring comprehensive and accurate results. For this purpose, we developed a custom browser extension, **2FA Extension**, tailored to the needs of our analysis. The extension captures cookies from the active browser session, generating a cookie snapshot of the visited site at a specific time. It can compare multiple snapshots to identify additions, deletions, or modifications to cookie attributes. The extension also offers an intuitive interface for selectively enabling or disabling individual cookies and includes functionality to clear browser data between experiments, maintaining a clean testing environment. It is important to note that the presence of 2FA-related cookies does not necessarily mean that a website relies solely on them to identify “trusted” devices. Thus, we proceed to the next stage.

3.3 Security Evaluation

In this stage (see step 3 in Figure 1), we first assess whether a website relies solely on 2FA Cookies to identify “trusted” devices or employs additional authentication methods. We also examine whether users are notified when a new login attempt is detected.

To determine whether a website relies solely on 2FA cookies to identify “trusted” devices, we first import the 2FA cookies obtained in step 2 to a new device with a different IP address and browser fingerprint. We then initiate the login process using the victim’s credentials. If the login proceeds without a new 2FA challenge, we classify the site as accepting the imported cookie state under the tested IP, browser, and geolocation conditions. This observation demonstrates portability of the recorded trust state; it does not establish that cookies are the only signal used in every session or context. Such a result enables our A3 replay-consequence test and identifies a potential exposure under A1 or A2 when the corresponding token-acquisition precondition is present; it is not, by itself, a confirmed A1–A3 exploit. Next, to assess whether login notifications are triggered, we monitor the victim’s registered email and phone number following the simulated 2FA bypass. The absence of alerts indicates that the victim remains unaware of the unauthorized login, leaving the account susceptible to undetected compromise.

We further analyze the security configuration of 2FA cookies. Misconfigured attributes (e.g., missing `HttpOnly` or `Secure` flags) can expose the system to attacks **A1** and **A2**. A remembered-device design that accepts a portable cookie without additional binding provides no residual device-specific protection after that cookie has been acquired. The resulting risk is therefore determined by the applicable token-acquisition capability (A1, A2, or A3) and by server-side lifecycle controls. A long expiration period is reported as an exposure-window amplifier, not as a standalone bypass. Finally, we investigate whether 2FA cookies contain fixed or predictable values, which could allow attackers to reuse or forge valid cookies and bypass the 2FA prompt without access to the victim’s legitimate tokens (**A4** attack).

4 Evaluation

To assess the security of 2FA systems on websites and the effectiveness of our attacks on real-world online services, we address the following research questions:

RQ1 (Adoption Study): How many popular websites currently support 2FA, what methods do they use for implementation, and how many of these websites offer a “Remember the Device” feature?

RQ2 (Vulnerability Detection): What vulnerabilities exist in cookie-based “trusted” device 2FA implementations, and how susceptible are these websites to the attacks we present?

4.1 Experiment Setup

In our evaluation, we set up two login environments, one for the victim and one for the attacker, with the following configurations:

- **Victim’s Setup:** A Windows 10 laptop using the Chrome browser (version 123.0.6312.87) and a smartphone with commonly used authenticator apps installed for 2FA.
- **Attacker’s Setup:** A Windows 11 laptop running the Firefox browser (version 124.0.2) and a smartphone with commonly used authenticator apps installed for 2FA.
- **Network and Fingerprinting Distinctions:** The two laptops were assigned unique IP addresses and placed in different geographical locations. Their browser fingerprints were verified as distinct using FingerprintJS [13].

4.2 Testing Procedure

In this section, we outline the methodology of our large-scale empirical analysis of 2FA systems.

Account Registration. For the 495 websites with registrable 2FA systems (see Table 2, excluding G1), we created two accounts for each site (one for each environment) and enabled 2FA on both accounts. The registration and 2FA setup were carefully performed to ensure normal site functionality. Due to the complexity of 2FA interactions, this process required human expertise and could not be automated.

Remembered-device identification. After enabling 2FA, we checked whether websites provided a “Remember the Device” or similar option, which typically appears in three places: (1) during login verification after completing the 2FA challenge; (2) in 2FA settings to mark a device as “trusted”; (3) as a “Remember Me” feature for sites without explicit 2FA trust options. Due to the variation in how 2FA interfaces are implemented, automatic detection of this feature is infeasible, so manual inspection by experts was required. In total, we identified 182 websites offering a “Remember the Device” feature (see G4 in Table 2).

Identifying Risk Control Measures. When a website offers a “Remember the Device” feature, we verify whether it uses a cookie-based risk control mechanism

to implement this functionality. To ensure the accuracy of the test results, we conduct experiments on each website in a clean, private browser mode to avoid interference from cookies from other sites. The specific steps are as follows: ❶ We log into the target website using the victim’s account without selecting the “Remember the Device” option after the 2FA verification, then use our *2FA Extension* to capture a cookie snapshot. After logging out, we record a second snapshot for the logged-out state. ❷ We repeat the login, this time selecting “Remember the Device” after 2FA verification, and use the *2FA Extension* to capture a cookie snapshot; after logging out, we save another snapshot. ❸ If the website employs a cookie-based method to identify trusted devices, enabling the “Remember the Device” option typically adds one or more cookies (such as `trustedDevice`) or extends the lifetime of existing authentication cookies. Because sites may set multiple or non-descriptive cookie names, we detect candidates by comparing the “Logged-in / Logged-out — Remembered” snapshots with their non-remembered counterparts using our extension’s *Compare Cookie Snapshots* feature. We flag cookies that are newly created after enabling the feature or that show a substantial increase in `expiration` as likely 2FA-related. Minor differences (small timestamp shifts or expected session cookie changes) are ignored; if no substantial changes are observed, we conclude the site does not rely on cookie-based risk control. ❹ For websites offering only the “Remember Me” option, we follow a similar testing process. Since this feature typically does not implement device-specific trust, we focus primarily on changes in cookie expiration times in the logged-in state. For example, after enabling this option, some websites significantly extend the expiration time of their authentication cookies, which allows skipping login and 2FA to some extent. On the “Games-5” website, for example, the `VT_SESSION_HASH` cookie’s expiration increased from 7 to 30 days (see Table 6). ❺ To determine whether sites enforce risk controls beyond cookies, we import the victim’s “Logged-out - Remembered” snapshot into an attacker-controlled browser that differs from the victim’s environment (different IP, browser, fingerprint, and geolocation) and attempt to log in with the victim’s credentials. If the system triggers 2FA verification again, this indicates that the website employs other risk control mechanisms in addition to cookies; if the login proceeds without a 2FA challenge, it can be assumed that it mainly relies on cookies to implement the “Remember the Device” feature.

Because 2FA workflows vary and require human interaction, the testing process cannot be fully automated. Three researchers used the 2FA Spider, 2FA Reviewer, and 2FA Extension together with manual inspection and controlled login tests. They completed the verification of the 2FA and remembered-device candidates in the Tranco Top 10,000 dataset within two calendar weeks. The recorded duration includes account setup, feature identification, cookie attribution, and exploit confirmation. Using our *2FA Extension* alongside manual analysis, we systematically tested the 182 websites in group G4 (Table 2).

Identifying Cookies Used for “Remember the Device”. For websites that accepted the imported cookie state under the tested IP/browser conditions, we first utilize the *Compare Cookie Snapshots* feature of our extension to identify

candidate 2FA cookies. Since not all identified cookies are used to determine device trust, we then validate candidates with the extension’s *Enable/Disable Cookie* feature: toggling specific cookies and observing whether the 2FA prompt is bypassed. Although this validation requires manual intervention, detailed enable/disable experiments and careful control records, let us precisely identify the 2FA cookies used for device trust determination, thereby providing a reliable empirical basis for subsequent security analysis.

Evaluating the Effectiveness of Cookie-Stealing Attacks. We identified the exact 2FA cookies used by 113 websites to support their 2FA systems (see Table 2). To verify whether these identified cookies can indeed be used to bypass the 2FA verification and to minimize false positives, we conduct the following validation in a controlled and authorized experimental environment: we imported the victim’s identified 2FA cookies into an attacker-controlled browser and attempted to log in to the target site with the victim’s credentials, recording whether the 2FA challenge was triggered or bypassed. Successful bypasses indicate that the cookies are exploitable in realistic attack scenarios.

After confirming exploitability, we audited the cookies’ security properties, checking attributes such as `Secure` and `HttpOnly`, and inspecting expiration times—to assess how they influence exposure. These checks allow us to classify the confirmed vulnerabilities according to the attack types described in Section 2.3 (e.g., **A1**, **A2**, **A3**) and to recommend appropriate mitigations.

Design Flaw Evaluation. When a site implements “Remember the Device” solely via cookies, insecure cookie value generation can create critical design flaws. If a 2FA cookie is merely a static flag or predictable, an attacker can forge or reuse it to bypass the second-factor challenge. To detect such design flaws, we performed the following tests: ❶ First, we logged into the target website using two distinct accounts and enabled “Remember the Device” on both the victim’s and the attacker’s devices. ❷ Next, we exported the 2FA cookies from both devices and inspected their contents for predictable or weakly-protected values, e.g., plaintext fields (e.g., IPs, fixed IDs), deterministic tokens, or trivially reversible encodings (e.g., Base64). If decoding reveals a predictable structure that can be reproduced, we classify the cookie as forgeable and vulnerable to replay or prediction attacks. ❸ Finally, we injected either the attacker’s validated 2FA cookie or a forged/predictable cookie into the attacker’s browser and attempted to authenticate to the victim’s account. If the login succeeds without a 2FA challenge, we classify the site as vulnerable. This means that attacker-supplied or predictable cookies can be reused to bypass the victim’s second-factor authentication. Such design flaws allow an attacker who obtains user credentials to bypass 2FA at scale, enabling large-scale account takeover and unauthorized access.

Detecting Notification of Suspicious Login Attempts. During evaluation, we monitored how the sites detect and respond to new login attempts, specifically whether they generate alerts when an attacker uses copied 2FA cookies to bypass the challenge. We logged instances where sites sent email or other notifications and summarized these findings in Table 5.

5 Results

Using SE2FA, as described in Sections 3 and 4, we evaluated the security of 2FA systems across websites in the Tranco top 10,000 list. Our study examined 495 websites with 2FA support (excluding websites in the G1 Group that cannot be registered), focusing on those offering the “Remember the Device” feature.

5.1 Overall Status(RQ1)

2FA Support Figure 2 shows the distribution of 2FA support across every 1,000 websites in the Tranco top 10,000, categorized by their ranking. Our findings indicate that higher-ranked websites are more likely to employ 2FA to protect user accounts. Our review also includes websites where we were unable to register (see G1 in Table 2). For these sites, we used our 2FA Spider to crawl search results and retrieve their 2FA documentation, confirming whether they offer 2FA support.

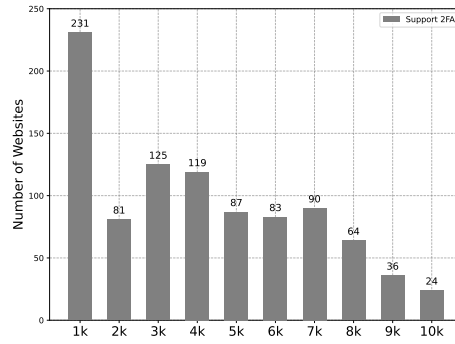


Fig. 2: 2FA Support By Ranking.

2FA Verification Methods Used In our analysis, we identified nine common 2FA methods used by 495 popular websites (excluding websites in G1 from Table 2 as we could not register with them), including authenticator apps, site-specific apps, and SMS (see Table 3). We distinguish site-specific apps (e.g., 360 Mobile Guard for so.com), which do not generate time-based one-time passwords (TOTP)s, from authenticator apps, which are dedicated TOTP generators. Authenticator apps are the most widely used, appearing on 295 websites. Most websites support only one 2FA method, though some offer up to five. Among sites with multiple options, authenticator apps are preferred, followed by SMS and email, for their user convenience. A few also support biometrics, hardware tokens, passkeys, and recovery codes.

2FA Verification Methods		Number of Methods Supported				
Method	Total	1	2	3	4	5
SMS	168	25	75	50	15	3
Phone Call	27	1	7	7	10	2
Specific App	115	30	40	28	14	3
Hardware Token	32	0	4	20	5	3
Email	148	44	55	34	12	3
Passkey	15	1	4	5	5	0
Authenticator App	295	178	64	38	11	4
Biometrics	10	0	3	3	2	2
Recovery Code	13	0	4	7	2	0

Table 3: The 2FA Verification Methods in Popular Websites.

5.2 Security Risks (RQ2)

Following the testing procedure in Section 4.2, we analyzed 940 websites and found 182 that support 2FA with a “Remember the Device” feature. We excluded sites in G1 (see Section 3.1) due to registration issues. Among the 182 sites, 113 (62%) accepted the remembered cookie state in our cross-environment test. This result identifies a portability property and a potential exposure if the state is stolen; it is not evidence that every such site is exploitable under A1, A2, or A3. For the remaining websites, we observed that some use browser fingerprints, while others rely on a combination of cookies, fingerprints, and IP address detection to manage the risk control measures of their 2FA systems. Additionally, we found one website that stored “trusted” device information in the web page’s `localStorage`. Similar to cookies, `localStorage` is a web storage mechanism that permanently stores data in key-value pairs within the user’s browser until explicitly deleted [22]. Since `localStorage` can also be accessed through XSS attacks, we consider it a special variant of 2FA cookies.

Security Issues in 2FA Cookie Management. We analyzed the attributes of 2FA cookies from websites that rely solely on them for “Remember the Device”. Due to page limit, Table 4 presents cookie attributes and related attacks for the top 500 websites; data for the rest websites is in Appendix Table 6.

For websites that use multiple cookies to identify a trusted device, we focus on the most secure cookie, as an attacker would need to obtain all 2FA cookies to successfully bypass the 2FA challenge and access the victim’s account. Given the seriousness of our findings, especially considering that accounts on these services are highly valuable and often targeted, we have chosen to anonymize the websites in our presentation. This includes anonymizing both the website names and the cookie names to protect their identities.

We found that the `Secure` attribute of 2FA cookies was not set on 15 websites. This is a potential transport-exposure condition for A1; we did not independently demonstrate an exploitable non-TLS path for each site. Additionally, the `HttpOnly` attribute of 2FA cookies was not set on 20 websites, including the website “Computers & Technology-38” that used `localStorage` to store trusted-device information. This is a potential script-access condition for A2; an

No.	Website	Cookie Attribute				Design Flaws (A4)	Attack Type
		Amount	HttpOnly	Secure	Expiries (days)		
1	Social Networking-1	1	✓	✓	400	-	A3
2	Computers & Technology-1	8	✗	✓	390	-	A2,A3
3	Computers & Technology-2	1	✓	✓	90	-	A3
4	Professional Networking-1	2	✗	✓	365	-	A2,A3
5	Shopping-1	1	✓	✓	365	-	A3
6	Computers & Technology-3	1	✓	✗	90	-	A1,A3
7	Computers & Technology-4	1	✓	✓	30	-	A3
8	Games-1	1	✓	✓	30	-	A3
9	Games-2	1	✓	✓	90	-	A3
10	Personal Storage-1	1	✓	✓	360	-	A3
11	Search Engines & Portals-1	1	✗	✗	365	-	A1,A2,A3
12	BusinessComputers & Technology-1	1	✓	✓	365	-	A3
13	Computers & Technology-5	1	✓	✓	30	-	A3
14	Business-1	1	✓	✓	14	-	A3
15	GamesForums & Newsgroups-1	1	✓	✓	30	●	A3, A4
16	Business-2	1	✓	✓	100	-	A3
17	Games-3	1	✓	✓	400	-	A3
18	Games-4	1	✓	✓	400	-	A3
19	Business-3	1	✓	✓	30	-	A3
20	Computers & Technology-6	1	✓	✓	90	-	A3
21	Computers & Technology-7	1	✓	✗	365	-	A1,A3
22	Computers & Technology-8	2	✓	✓	90	-	A3
23	Computers & Technology-9	1	✓	✗	90	-	A1,A3

Table 4: Top 500 Websites Vulnerable to **A1**, **A2**, **A3** and **A4** Attacks. ✓:2FA Cookie attribute set to **true**, ✗: 2FA Cookie attribute set to **false**, ●: Design flaw - cross account reuse.

exploitable XSS path would also be required. For A3, importing a victim cookie into a distinct browser demonstrates that the trust state is not bound to the tested browser environment. A malicious extension or malware with browser-level access could consequently read the state, but this is an endpoint-compromise capability that can also affect ordinary session cookies and other browser credentials. We therefore present A3 as a residual risk of portable client-side trust state, not as a cookie-specific zero-day.

We also evaluated the expiration time of the 2FA cookies we collected. Our findings show that only seven websites set the expiration time of their 2FA cookies to 7 days or less. Less than half of the websites set this attribute to less than 30 days, with the most common setting being 30 days. 22 websites even set the expiration time to 400 days. A long cookie expiration time increases the exposure window. Once an attacker has obtained a usable trust cookie, the attacker may be able to bypass the user’s 2FA challenge until the cookie expires or is revoked; the expiration observation alone does not establish a bypass without token acquisition.

5.3 Design Flaws (RQ2)

Our analysis uncovered three previously undisclosed remembered-device logic flaws.

Case Studies. For instance, on the “GamesForums & Newsgroups-1” website, after the victim enabled the “Remember the Device” option, attackers could bypass the victim’s 2FA challenge using their own 2FA cookies without needing access to the victim’s cookies, indicating a serious security flaw in the site’s 2FA system. Additionally, we found that the “Remember the Device” feature on two

websites was poorly designed, making the 2FA cookies predictable or forgeable. For example, on “Computers & Technology-27”, after enabling “Remember the Device”, the `otp_verified_at` cookie used to bypass 2FA was set as a timestamp. Attackers could easily forge this cookie to gain unauthorized access to the victim’s account. On another website, “Computers & Technology-33”, the trusted device 2FA cookie consisted only of the user’s IP, login date, and one-time password (OTP). Compared to encrypted, high-entropy cookies, these are easy for attackers to predict and forge, allowing them to bypass 2FA verification.

We responsibly disclosed all three cases, providing reproduction videos and remediation recommendations; as of our testing when writing this paper, the affected providers had fixed them. We also observed two websites whose trust cookies were Base64-encoded and exposed fields such as an IP address, but were appended with a hash-like string. We do not infer forgeability from this encoding alone. Finally, we found that “stubhub.com” claimed to offer 2FA during login, but it did not trigger. We reported this issue to the site’s developers, and subsequent tests confirmed it had been fixed.

6 Discussion

While 2FA improves security, repeated 2FA challenges can frustrate users, leading some to disable it. To improve usability, 37% of these sites (182 of 495) have implemented a “Remember the Device” feature. Our measurements show that implementations relying on portable client-side state can expose a larger attack surface when that state is stolen or when the endpoint is compromised; the severity depends on the attacker’s capabilities and on server-side binding and lifecycle controls.

6.1 Lessons learned

Most of the vulnerabilities described in Section 5 are caused by how service providers handle 2FA cookies and the design choices made for managing these cookies. We next consider in greater detail how and why the various classes of vulnerability that we have identified have arisen.

Improperly Managed 2FA Cookies. When a website relies only on cookies to manage risk controls for its 2FA system, careful handling of these cookies is crucial for preventing security vulnerabilities. However, our security analysis found that 22% of these websites (26 out of 113) did not follow the best practices to set the `Secure` and `HttpOnly` attributes. Additionally, more than 87% (98 out of 113) of these websites set their cookie expiration period to 30 days or longer, with 34 websites even setting the expiration time to one year or longer.

Setting a long expiration period or omitting an expiration time entirely for 2FA cookies further widens the window of vulnerability. If an attacker gains access to a user’s 2FA cookies via an XSS or network sniffing attack, they can bypass the 2FA challenge and maintain unauthorized access to the account until the cookies expire. For example, the “Search Engines & Portals - 1” website (see

Table 4) set the expiration time for their 2FA cookies to 365 days and also left both `Secure` and `HttpOnly` flags disabled.

Put all Eggs in One Basket. As discussed in Section 2.2, various measures could be used to manage risk controls in 2FA systems. The “Remember the Device” feature should be implemented without sacrificing the security of the underlying 2FA system. Our security analysis revealed that 62% (113 out of 182) of these websites accepted cookie state across the tested environments. This exclusive reliance on portable client-side state provides no additional protection after a trust cookie has been stolen; whether an attacker can steal it depends on the applicable network, web, or endpoint threat.

6.2 Limitations and Future Work

These limitations qualify the scope of our measurements, but they do not change the mechanism-level conclusion established earlier. When a service accepts a 2FA cookie as the sole trust proof and does not enforce additional account or device binding, possession of a still-valid value is sufficient for replay in our tested workflow. This is a conditional mechanism-level result; it does not estimate the likelihood of token theft or endpoint compromise. Our A3 experiment assumes browser-level endpoint compromise and tests whether any additional binding remains after importing the trust state into a distinct environment. It therefore measures the consequence of token acquisition, rather than the likelihood of endpoint compromise. Similarly, missing `Secure` or `HttpOnly` flags identify exposure conditions; exploiting them still requires the corresponding unprotected HTTP or XSS precondition. We did not estimate token entropy, perform statistical randomness tests, recover server-side signing keys, or prove resistance under adaptive token-generation queries.

At the measurement level, account registration, feature identification, cookie attribution, and exploit confirmation required expert interaction. The comparison with the 2FA Directory should be understood as a dataset-overlap measurement rather than an independent accuracy evaluation, since we did not construct an adjudicated gold-standard set. We also did not systematically measure SameSite policies, token binding, token rotation, or revocation after logout, password changes, 2FA resets, or device removal. Future work should evaluate the LLM component with a stratified human-labeled benchmark, collect larger samples and complete trust-token lifecycles, and repeat the study across different datasets, regions, and time periods.

6.3 Mitigation

Our security analysis has revealed severe vulnerabilities in 2FA systems that offer a “Remember the Device” feature. There is a significant danger that these vulnerabilities will be replicated in future systems. To prevent similar flaws in future implementations, we propose the following recommendations.

Best Practices for Securing 2FA Cookie Implementation: Implementing robust cookie security practices is essential to protect 2FA cookies from unauthorized access. Service providers should enable both the `Secure` and `HttpOnly` attributes to prevent cookie exposure through insecure connections and mitigate XSS risks. Additionally, setting a short expiration time for 2FA cookies, ideally within a few days, can effectively limit the potential misuse of stolen cookies and reduce the overall attack surface.

Combining Multiple Risk Control Measures: Our analysis shows that relying solely on cookies for managing risk in 2FA systems is insufficient and insecure. To strengthen the “Remember the Device” feature, service providers should combine multiple risk control measures, such as browser fingerprinting to identify unique devices, IP address and geolocation checks to detect unusual login locations, and behavioral analytics to monitor login frequency and device-switching patterns. Integrating these factors enables more accurate risk assessment and ensures that additional authentication is triggered when anomalies occur.

Adopting Secure Authentication Mechanisms: Previous studies have shown that single sign-on (SSO) mechanisms can mitigate the risks associated with cookie-based authentication [12,33]. By using a centralized authentication service to issue short-lived tokens, SSO replaces reliance on long-lived, persistent cookies. In addition, FIDO2/Passkeys - designed for high security scenarios - use asymmetric cryptography to enable passwordless authentication [11,14].

User Notifications for New Login Attempts: Our analysis found that 45 websites send email alerts for new or suspicious logins, helping users respond quickly to potential threats (Table 5). Some sites also trigger password resets after failed login attempts. Table 5 details the types of email notifications observed during our simulated attacks.

Notification Type	Description	Number
N1	New device login notification only	24
N2	New device login time and location notification	12
N3	Abnormal IP login notification	5
N4	Suspicious login verification	2
N5	Unauthorized login attempt notification and automatic password reset	1
N6	Notification that the 2FA code is incorrect but the account password is correct	1

Table 5: Types of Email Notifications Sent When a New Login Attempt is Detected.

7 Related Work

To the best of our knowledge, this study is the first large-scale black-box measurement focused on web 2FA remembered-device behavior that combines observable cookie auditing with controlled cross-environment replay and logic tests. This scope claim does not cover generic session-cookie studies, U2F-only analyses, or browser-fingerprinting research.

Cookie Security. Drakonakis et al. [9] developed an automated auditing framework that uncovered widespread authentication and authorization flaws related to cookie handling across 25K domains, including session and cookie hijacking. Despite HTTPS use, many sites lacked proper HSTS, exposing them to attacks. Calzavara et al. [5] analyzed client-side security policies on 15,000 sites, revealing inconsistent cookie attributes, CSP, and HSTS use—leading to XSS and cookie theft. They found the Origin Policy proposal inadequate and proposed a Site Policy framework with prototype and tool support.

2FA Security. Shrestha et al. [30] showed attackers can exploit predictable phone sounds to bypass ambient audio-based 2FA. Sun et al. [32] introduced an OTP system using ARM TrustZone, combining software flexibility with hardware security even if the OS is compromised. Reaves et al. [26] conducted a longitudinal study on SMS-based security, exposing how defenses like phone verification are circumvented. Thomas et al. [6] studied credential theft underground, revealing millions at risk and showing enhanced authentication reduces hijacking. Lin et al. [20] demonstrated that attackers can spoof browser fingerprints to bypass 2FA on valuable services. Patat et al. [25] conducted the first systematic security analysis of the “Remember Me” functionality in U2F protocols, revealing design flaws and practical attack vectors in how major websites implement this feature using cookies. However, their study was limited in scope, covering only specific 2FA types and a relatively small set of websites.

8 Conclusion

In this paper, we introduced **SE2FA**, a hybrid framework for evaluating web-based two-factor authentication (2FA) systems that provide a “Remember the Device” option. Applying SE2FA to the Tranco Top 10,000 list, we identified 940 2FA-supporting websites, of which 495 were available for account-based testing; 182 offered the remembered-device option, and 113 accepted imported trust state under our cross-environment conditions. We further found that 26 websites used 2FA cookies without ‘Secure’ or ‘HttpOnly’ attributes, weakening the protection of remembered-device state. These observations demonstrate portability of the tested trust state and identify potential exposure when the state is acquired. We also confirmed three previously undisclosed logic flaws involving cross-account reuse or constructible trust values and responsibly disclosed them to the affected providers. Our findings show that remembered-device mechanisms should enforce account and device binding, protect trust values, and provide appropriate expiration and revocation controls.

References

1. Al-Fannah, N.M., Li, W., Mitchell, C.J.: Beyond cookie monster amnesia: Real world persistent online tracking. In: Information Security. pp. 481–501. Springer International Publishing (2018). https://doi.org/10.1007/978-3-319-99136-8_26
2. Andriamilanto, N., Allard, T., Le Guelvouit, G., Garel, A.: A large-scale empirical analysis of browser fingerprints properties for web authentication. In: Proceedings of the 2021 ACM SIGSAC Conference on Computer and Communications Security (2021). <https://doi.org/10.1145/3478026>
3. Berrios, J., Mosher, E., Benzo, S., Grajeda, C., Baggili, I.: Factorizing 2fa: Forensic analysis of two-factor authentication applications. *Forensic Science International: Digital Investigation* **45**, 301569 (2023)
4. Bruun, A., Jensen, K., Kristensen, D.: Usability of single- and multi-factor authentication methods on tabletops: A comparative study. In: Human-Centered Software Engineering. pp. 299–306 (2014)
5. Calzavara, S., Urban, T., Tatang, D., Steffens, M., Stock, B.: Reining in the web’s inconsistencies with site policy. In: Proceedings of the 2021 Network and Distributed System Security Symposium (2021). <https://doi.org/10.14722/ndss.2021.23091>
6. Das, A., Bonneau, J., Caesar, M., Borisov, N., Wang, X.: The tangled web of password reuse. In: Proceedings of the Network and Distributed System Security Symposium (2014). <https://doi.org/10.14722/ndss.2014.23357>
7. Dastane, D.O.: The effect of bad password habits on personal data breach. *International Journal of Emerging Trends in Engineering Research* **8**(10) (2020)
8. De Cristofaro, E., Du, H., Freudiger, J., Norcie, G.: A comparative usability study of two-factor authentication. In: Proceedings of the 2014 Workshop on Usable Security. Internet Society (2014). <https://doi.org/10.14722/usec.2014.23025>
9. Drakonakis, K., Ioannidis, S., Polakis, J.: The cookie hunter: Automated black-box auditing for web authentication and authorization flaws. In: CCS ’20: 2020 ACM SIGSAC Conference on Computer and Communications Security. pp. 1953–1970 (2020)
10. Eldefrawy, M.H., Alghathbar, K., Khan, M.K.: Otp-based two-factor authentication using mobile phones. In: 2011 Eighth International Conference on Information Technology: New Generations. pp. 327–331. IEEE (2011)
11. Farke, F.M., Lorenz, L., Schnitzler, T., Markert, P., Dürmuth, M.: You still use the password after all: Exploring fido2 security keys in a small company. In: Sixteenth Symposium on Usable Privacy and Security. pp. 19–35 (2020)
12. Fett, D., Küsters, R., Schmitz, G.: Spresso: A secure, privacy-respecting single sign-on system for the web. In: Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security. pp. 1358–1369 (2015). <https://doi.org/10.1145/2810103.2813726>
13. FingerprintJS Project: Fingerprintjs: Browser fingerprinting library. <https://github.com/fingerprintjs/fingerprintjs> (2024), accessed 7 November 2024
14. Ghorbani Lyastani, S., Schilling, M., Neumayr, M., Backes, M., Bugiel, S.: Is fido2 the kingslayer of user authentication? a comparative usability study of fido2 passwordless authentication. In: 2020 IEEE Symposium on Security and Privacy. pp. 268–285 (2020). <https://doi.org/10.1109/SP40000.2020.00047>
15. Hsieh, W.B., Leu, J.S.: Design of a time and location based one-time password authentication scheme. In: 2011 7th International Wireless Communications and Mobile Computing Conference. pp. 165–170. IEEE (2011)

16. Huang, C.Y., Ma, S.P., Chen, K.T.: Using one-time passwords to prevent password phishing attacks. *Journal of Network and Computer Applications* **34**(4), 1292–1301 (2011)
17. Jacomme, C., Kremer, S.: An extensive formal analysis of multi-factor authentication protocols. *ACM Transactions on Privacy and Security* **24**(2), 1–34 (2021)
18. Jannett, L., Westers, M., Wich, T., Mainka, C., Mayer, A., Mladenov, V.: Sok: Ssomonitor—the current state and future research directions in single sign-on security measurements. In: 2024 IEEE 9th European Symposium on Security and Privacy. pp. 173–192. IEEE (2024)
19. Katsini, C., Belk, M., Fidas, C., Avouris, N., Samaras, G.: Security and usability in knowledge-based user authentication: A review. In: Proceedings of the 20th Pan-Hellenic Conference on Informatics. pp. 1–6 (2016)
20. Lin, X., Ilia, P., Solanki, S., Polakis, J.: Phish in sheep’s clothing: Exploring the authentication pitfalls of browser fingerprinting. In: 31st USENIX Security Symposium. pp. 1651–1668 (2022)
21. Mirante, D., Cappos, J.: Understanding password database compromises. Tech. Rep. TR-CSE-2013-02, Polytechnic Institute of New York University (2013)
22. Mozilla Developer Network: Window: localStorage property. <https://developer.mozilla.org/en-US/docs/Web/API/Window/localStorage> (2024), accessed 13 November 2024
23. OWASP: Man-in-the-browser attack. https://owasp.org/www-community/attacks/Man-in-the-browser_attack (2024), accessed 5 June 2024
24. Pantelaivos, N., Nikiforakis, N., Kapravelos, A.: You’ve changed: Detecting malicious browser extensions through their update deltas. In: Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security. pp. 477–491 (2020)
25. Patat, G., Sabt, M.: Please remember me: Security analysis of u2f remember-me implementations in the wild. In: Actes SSTIC 2020 (2020)
26. Reaves, B., Scaife, N., Tian, D., Blue, L., Traynor, P., Butler, K.R.B.: Sending out an sms: Characterizing the security of the sms ecosystem with public gateways. In: 2016 IEEE Symposium on Security and Privacy (2016). <https://doi.org/10.1109/SP.2016.28>
27. Rodríguez, G.E., Benavides, D.E., Torres, J., Flores, P., Fuertes, W.: Cookie scout: An analytic model for prevention of cross-site scripting using a cookie classifier. In: International Conference on Information Technology and Systems. pp. 497–507. Springer (2018)
28. Saltzman, R., Sharabani, A.: Active man in the middle attacks. OWASP AU (2009)
29. SearXNG Project: Searxng: A privacy-respecting metasearch engine. <https://github.com/searxng/searxng> (2024), accessed 7 November 2024
30. Shrestha, B., Shirvanian, M., Shrestha, P., Saxena, N.: The sounds of the phones. In: Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security (2016). <https://doi.org/10.1145/2976749.2978328>
31. Sivakorn, S., Keromytis, A.D., Polakis, J.: That’s the way the cookie crumbles: Evaluating https enforcing mechanisms. In: Proceedings of the 2016 ACM Workshop on Privacy in the Electronic Society. pp. 71–81 (2016)
32. Sun, H., Sun, K., Wang, Y., Jing, J.: Trustotp: Transforming smartphones into secure one-time password tokens. In: Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security. pp. 976–988 (2015)
33. Sun, S.T., Pospisil, E., Muslukhov, I., Dindar, N., Hawkey, K., Beznosov, K.: Investigating users’ perspectives of web single sign-on. *ACM Transactions on Internet Technology* **13**(1) (2013)

34. Tyler, L., Nunes, I.D.O.: Towards browser controls to protect cookies from malicious extensions. arXiv preprint arXiv:2405.06830 (2024)
35. Vastel, A., Laperdrix, P., Rudametkin, W., Rouvoy, R.: Fp-stalker: Tracking browser fingerprint evolutions. In: 2018 IEEE Symposium on Security and Privacy. pp. 728–741. IEEE (2018)
36. Wiefling, S., Lo Iacono, L., Dürmuth, M.: Is this really you? an empirical study on risk-based authentication applied in the wild. In: ICT Systems Security and Privacy Protection. pp. 134–148. Springer (2019)
37. Yen, T.F., Xie, Y., Yu, F., Yu, R.P., Abadi, M.: Host fingerprinting and tracking on the web: Privacy and security implications. In: Proceedings of the Network and Distributed System Security Symposium (2012)

A Security Evaluation

Table 6 presents the cookie attributes and their associated attacks for the top 500 to 10,000 websites that rely solely on cookies to protect their “Remember the Device” feature.

No.	Website	Cookie Attribute				Design Flaws (A4)	Attack Type
		Amount	HttpOnly	Secure	Expires (days)		
24	Computers & Technology-10	1	✓	✓	30	-	A3
25	Computers & Technology-11	1	✓	✓	90	-	A3
26	Search Engines & Portals-2	1	✓	✓	30	-	A3
27	Computers & Technology-12	1	✗	✓	30	-	A2,A3
28	Pornography/Sexually Explicit-1	1	✓	✓	400	-	A3
29	Business-4	2	✓	✓	30	-	A3
30	Computers & Technology-13	1	✗	✗	90	-	A1,A2,A3
31	Computers & Technology-14	1	✓	✓	30	-	A3
32	Education-1	1	✓	✓	200	-	A3
33	Travel-1	3	✓	✓	180	-	A3
34	Social NetworkingArts-1	1	✓	✓	200	-	A3
35	Social NetworkingEntertainmentBusiness-1	1	✓	✓	▼	-	A3
36	Computers & Technology-15	1	✗	✓	400	-	A2,A3
37	Games-5	1	✓	✓	400	-	A3
38	Business-5	2	✓	✓	30	-	A3
39	Computers & Technology-16	2	✓	✓	7	-	A3
40	Remote Access-1	1	✓	✓	2	-	A3
41	Computers & Technology-17	1	✓	✓	30	-	A3
42	Pornography/Sexually Explicit-2	1	✓	✓	400	-	A3
43	Computers & Technology-18	1	✓	✓	400	-	A3
44	Computers & Technology-19	1	✓	✓	14	-	A3
45	Computers & Technology-20	1	✓	✓	30	-	A3
46	Transportation-1	1	✗	✓	30	-	A2,A3
47	Computers & Technology-21	1	✗	✗	90	-	A1,A2,A3
48	Computers & Technology-22	1	✗	✓	7	-	A2,A3
49	Computers & Technology-23	1	✓	✗	30	-	A1,A3
50	Computers & Technology-24	1	✗	✓	400	-	A2,A3
51	BusinessComputers & Technology-2	1	✓	✓	30	-	A3
52	Games-6	1	✓	✓	30	-	A3
53	FinanceComputers & Technology-1	1	✓	✓	30	-	A3
54	Education-2	1	✓	✓	400	-	A3
55	Computers & Technology-25	1	✓	✓	400	-	A3
56	Computers & Technology-26	1	✓	✓	90	-	A3
57	Computers & Technology-27	1	✓	✓	7	●	A3,A4
58	Image Sharing-1	1	✓	✓	30	-	A3
59	Computers & Technology-28	1	✓	✓	400	-	A3
60	Computers & TechnologyBusiness-1	1	✓	✓	30	-	A3
61	Information Security-1	1	✓	✓	90	-	A3
62	EntertainmentForums & Newsgroups-1	2	✓	✓	400	-	A3
63	Computers & Technology-29	1	✓	✓	400	-	A3
64	Computers & Technology-30	1	✓	✓	365	-	A3
65	EntertainmentStreaming Media & Downloads-1	1	✓	✓	30	-	A3
66	Computers & Technology-31	1	✓	✓	365	-	A3
67	Computers & Technology-32	1	✗	✗	▼	-	A1,A2,A3
68	Computers & Technology-33	1	✓	✓	400	●	A3
69	Games-7	1	✓	✓	100	-	A3,A4
70	Computers & Technology-34	1	✗	✓	▼	-	A2,A3
71	Computers & TechnologyBusiness-2	1	✓	✓	30	-	A3
72	Computers & Technology-35	1	✗	✗	45	-	A1,A2,A3
73	Real Estate-1	1	✓	✓	400	-	A3
74	Business-6	1	✓	✗	400	-	A1,A3
75	Computers & Technology-36	1	✓	✓	180	-	A3
76	Computers & Technology-37	1	✓	✓	180	-	A3
77	Computers & Technology-38	1	-	-	◆	-	A2,A3
78	ShoppingComputers & Technology-1	1	✗	✓	400	-	A2,A3
79	Computers & Technology-39	1	✓	✓	365	-	A3
80	Computers & Technology-40	3	✓	✓	7	-	A3
81	Computers & Technology-41	1	✓	✓	400	-	A3
82	Transportation-2	2	✓	✓	30	-	A3
83	Computers & Technology-42	2	✓	✓	30	-	A3
84	Shopping-2	1	✓	✓	7	-	A3
85	Business-7	2	✓	✓	30	-	A3
86	Computers & Technology-43	1	✓	✓	90	-	A3
87	Computers & Technology-44	3	✗	✗	90	-	A1,A2,A3
88	Computers & Technology-45	2	✓	✓	400	-	A3
89	Computers & Technology-46	1	✓	✓	90	-	A3
90	Government-1	1	✓	✓	30	-	A3
91	Business-8	1	✓	✓	14	-	A3
92	GamesForums & Newsgroups-2	1	✓	✓	45	-	A3
93	Computers & TechnologyBusiness-3	1	✗	✗	90	-	A1,A2,A3
94	Real EstateComputers & Technology-1	1	✓	✓	7	-	A3
95	Computers & Technology-47	1	✓	✓	30	-	A3
96	Business-9	2	✗	✓	30	-	A2,A3
97	BusinessComputers & Technology-3	1	✓	✓	14	-	A3
98	Shopping-3	1	✓	✓	365	-	A3
99	Health & Medicine-1	1	✓	✓	30	-	A3
100	Image Sharing-2	1	✓	✓	30	-	A3
101	Computers & Technology-48	1	✓	✓	400	-	A3
102	Government-2	1	✓	✓	30	-	A3
103	Computers & Technology-49	1	✓	✓	45	-	A3
104	Shopping-4	2	✓	✓	365	-	A3
105	Computers & Technology-50	1	✓	✓	90	-	A3
106	Computers & Technology-51	1	✓	✓	400	-	A3
107	Computers & Technology-52	1	✗	✗	400	-	A1,A2,A3
108	BusinessComputers & Technology-4	1	✓	✓	30	-	A3
109	Computers & Technology-53	2	✗	✗	90	-	A1,A2,A3
110	Computers & Technology-54	1	✓	✓	90	-	A3
111	Computers & Technology-55	1	✓	✓	30	-	A3
112	Computers & Technology-56	1	✓	✗	30	-	A1,A3
113	Computers & Technology-57	1	✓	✓	90	-	A3

Table 6: Top 500–10,000 Websites Vulnerable to A1, A2, A3 and A4 Attacks.

✓: 2FA cookie attribute set to true, ✗: 2FA cookie attribute set to false, ●: Design flaw – cross account reuse, ●: Design flaw – predictable cookie value, ▼: 2FA cookies are session cookies, ◆: Storing 2FA cookies in localStorage.